

Security Fundamentals

1. Information Security

Meaning

Information Security (InfoSec) means protecting information and information systems from unauthorized access, modification, disclosure, destruction, or disruption. Information can exist in many forms: Digital files, Databases, Emails, Network traffic. The main goal is to keep information **safe, accurate, and available**.

Purpose of Information Security

Information Security protects data from: Unauthorized access, Data theft, Data modification, Malware, Ransomware, Accidental deletion.

Example

Suppose a company stores customer banking information. Security controls can include:

Firewall → Authentication → Encryption → Access Control → Monitoring → Backup

These controls protect customer information.

Interview Definition

Information Security is the practice of protecting information and systems from unauthorized access, disclosure, modification, destruction, or disruption while maintaining confidentiality, integrity, and availability.

2. CIA Triad

The **CIA Triad** is the foundation of Information Security.

CIA Triad → Confidentiality + Integrity + Availability

CIA stands for: **C — Confidentiality, I — Integrity, A — Availability**

2.1 Confidentiality

Meaning

Information should be accessible only to authorized users. It prevents unauthorized people from seeing sensitive information.

Examples

Passwords, Bank account information, Medical records, Company confidential documents.

Controls used for Confidentiality

Encryption, Authentication, Access Control, MFA, VPN, File permissions, Network segmentation.

Example

Suppose only HR employees should access employee salary data.

```
Normal Employee → Denied  
HR Employee → Authentication → Allowed
```

This maintains **Confidentiality**.

2.2 Integrity

Meaning

Data should remain accurate, complete, and unchanged unless an authorized person modifies it.

Controls used for Integrity

Hashing, Digital signatures, Checksums, File integrity monitoring, Access control, Database permissions.

Example

```
Original File → Hash → SHA-256 = ABC123...  
File Modified → New Hash → SHA-256 = XYZ789...
```

Different hash indicates that the file was modified.

2.3 Availability

Meaning

Authorized users should be able to access systems and information whenever they need them.

Threats to Availability

DoS, DDoS, Hardware failure, Power failure, Ransomware, Network failure, Server failure.

Controls used for Availability

Backups, Load balancers, Redundant servers, UPS, Disaster recovery, High availability, DDoS protection, Monitoring.

2.4 Security vs Privacy

Meaning

Security and **Privacy** are related but different concepts, and this distinction is a very common interview question.

Security is about protecting data and systems from unauthorized access, damage, or disruption — it is the set of controls (technical, physical, administrative) used to keep information and systems safe.
Privacy is about the right of an individual or organization to control how their personal data is collected, used, shared, and stored — it is about *who is allowed to see and use data*, not just how well it is protected.

Security → Protects data (the "how")
Privacy → Governs use of data (the "who/why")

Working Relationship

Security is a **means** to achieve Privacy. Without good security, privacy cannot be guaranteed — but strong security alone does not guarantee privacy.

Strong Security + No Privacy Policy → Data is well protected → But data may still be misused, sold, or over-collected
Weak Security + Strong Privacy Policy → Good intentions on paper → But data can still be stolen or leaked

Both are required together.

Examples

Scenario	Security Concern	Privacy Concern
Hospital database hacked	Data was accessed without authorization	Patient medical history exposed
Company sells user data to advertisers without consent	No breach — system was secure	User data used without permission
Employee views customer records out of curiosity	Access control worked (employee was authorized)	Unauthorized <i>use</i> of data (no legitimate reason)
Weak encryption on a banking app	Data can be intercepted	Financial and personal details at risk

Pros and Cons

Security — Pros: Prevents breaches, protects systems, builds trust. Cons: Can be costly and complex to implement fully. **Privacy** — Pros: Protects individual rights, builds regulatory compliance and trust. Cons:

Requires policy, consent management, and legal awareness — not just technical controls.

Use Cases

Security controls: firewalls, encryption, MFA, access control, IDS/IPS. **Privacy controls:** consent forms, data minimization, data retention policies, anonymization, GDPR/DPDP compliance, privacy-by-design.

Common Privacy Principles (used in laws like GDPR / India's DPDP Act)

1. Data Minimization → Collect only what is needed
2. Purpose Limitation → Use data only for the stated purpose
3. Consent → Get user permission before collecting/using data
4. Right to Access → User can see what data is held about them
5. Right to Erasure → User can request deletion ("right to be forgotten")
6. Data Retention Limits → Don't keep data longer than needed
7. Breach Notification → Inform users/authorities if data is compromised

Interview Definition

Security protects information from unauthorized access and damage using technical and administrative controls, while Privacy governs how personal data is collected, used, and shared with the individual's consent. Security is necessary for privacy, but security alone does not guarantee privacy.

3. Vulnerability

Meaning

A weakness in a system, application, network, configuration, or process that can be exploited. A vulnerability itself is not an attack. It is a **weakness that may allow an attack**.

Examples

Weak password, Unpatched software, Open unnecessary ports, Misconfigured firewall, Default credentials, SQL injection vulnerability, Incorrect file permissions, Publicly exposed database. Weak password = **Vulnerability**. An attacker may use brute force to exploit it.

4. Threat

Meaning

Anything that has the potential to exploit a vulnerability and cause damage. Threats can be: Human, Technical, Natural, Accidental.

Examples

Hacker, Malware, Ransomware, Insider, DDoS attack.

Example

Weak Password → Vulnerability
Attacker attempting brute force → Threat

5. Risk

Meaning

The possibility that a threat will exploit a vulnerability and cause damage.

$\text{Risk} = \text{Likelihood} \times \text{Impact}$

Likelihood

How likely is the attack to happen? Low, Medium, High.

Impact

How serious would the damage be? Data loss, Financial loss, Downtime, Reputation damage, Legal penalties.

Example

Suppose: Database exposed to Internet + Weak Password + Sensitive Customer Data. The risk is high because exploitation is possible and impact would be serious.

6. Vulnerability vs Threat vs Risk

This is a very common interview question.

Term	Meaning	Example
Vulnerability	Weakness	Weak SSH password
Threat	Something that may exploit weakness	Hacker
Risk	Possible damage	Server compromise
Countermeasure	Protection	MFA + firewall

Example

Weak Password → Vulnerability
Attacker → Threat
Account Compromise → Risk
MFA + Strong Password → Countermeasure

Interview Answer

A vulnerability is a weakness, a threat is something that can exploit that weakness, and risk is the possible loss or damage that may happen if the threat successfully exploits the vulnerability.

7. Attack Vector

Meaning

The path or method an attacker uses to gain unauthorized access to a system. It answers: **How did the attacker enter?**

Common Attack Vectors

Phishing email, Weak passwords, Exposed RDP, Exposed SSH, Vulnerable web application, Malware attachment, USB device, VPN account, Public cloud misconfiguration, Social engineering.

Example

Attacker → Phishing Email → Employee Clicks Link → Credentials Stolen → Company Account Compromised

Attack Vector: **Phishing Email**

8. Attack Surface

Meaning

The total number of possible points where an attacker may try to enter or attack a system. The larger the attack surface, the more opportunities attackers have.

Examples

A server may have: SSH → 22, HTTP → 80, HTTPS → 443, RDP → 3389, MySQL → 3306. If all are exposed to the Internet, the attack surface becomes larger.

Attack Surface Can Include

Open ports, APIs, Web applications, User accounts, Cloud services, Network devices, Remote access services, Third-party applications, Employees.

How to Reduce Attack Surface

Close unnecessary ports, Remove unused services, Disable unused accounts, Patch systems, Network segmentation, Use firewall rules, Apply least privilege.

Example

Before: 22, 80, 443, 3306, 3389
After hardening: 443

Attack surface is reduced.

This "hardening" step is a full practice on its own — see **Section 13.1 Server Hardening** below.

9. Attack Vector vs Attack Surface

Attack Vector	Attack Surface
Method used to attack	All possible attack points
How attacker enters	Where attacker could enter
Example: Phishing	Example: Email, VPN, SSH, Web App

Attack Surface: Web App + SSH + VPN + Email
Attack Vector Used: Phishing Email

10. Exposure

Meaning

The extent to which a system, service, or asset is accessible or visible to potential threats.

Example

A database configured as `0.0.0.0/0 → TCP 3306` means anyone on the Internet may attempt to connect to it. This creates high **exposure**.

Examples of Exposure

Database publicly accessible, RDP open to the Internet, Public S3 bucket, Sensitive file exposed through web server, Admin panel available publicly.

Exposure vs Vulnerability

Exposure	Vulnerability
System is reachable/exposed	System contains weakness
Example: SSH open publicly	Example: Weak SSH password

Together they can create serious risk.

11. Countermeasure

Meaning

A security control used to reduce, prevent, detect, or respond to a security risk.

Examples

Risk	Countermeasure
Weak password	Strong password + MFA
Open unnecessary port	Firewall
Malware	Antivirus/EDR
DDoS	Rate limiting/CDN/DDoS protection
Data theft	Encryption
File modification	File integrity monitoring
Brute force	Fail2ban

Example

Threat: Brute Force | Vulnerability: Weak Password | Risk: Account Compromise
Countermeasure: MFA + Strong Password + Fail2ban

12. Risk Management

Meaning

The process of identifying, analyzing, treating, and monitoring security risks.

Identify → Assess → Prioritize → Treat → Monitor

Step 1 — Identify Risk

Find: Assets, Threats, Vulnerabilities. Example: Asset → Database, Threat → Attacker, Vulnerability → Weak Password.

Step 2 — Assess Risk

Determine Likelihood and Impact. Example: Likelihood = High, Impact = Critical → Risk = Critical.

Step 3 — Prioritize Risk

Fix high-risk problems first. Example: Critical → Fix immediately, High → Fix quickly, Medium → Plan remediation, Low → Monitor.

Step 4 — Treat Risk

There are four common approaches.

- **Risk Mitigation** — Reduce the risk. Example: Weak Password → Strong Password + MFA
- **Risk Avoidance** — Stop the risky activity. Example: A company stops using an insecure application.
- **Risk Transfer** — Transfer some financial responsibility. Example: Cyber insurance.
- **Risk Acceptance** — Accept the risk if the cost of fixing it is greater than the expected impact.

Step 5 — Monitor Risk

Security risks change over time. Monitor: New vulnerabilities, New attacks, Configuration changes, Security logs, Software updates.

13. Security Control

Meaning

A measure used to protect systems, networks, data, and users. Security controls are commonly classified as: Preventive, Detective, Corrective.

Preventive Controls

Prevent an attack from happening. Examples: Firewall, MFA, Encryption, Access control, Strong passwords, Network segmentation.

Attack → Firewall → Blocked

Detective Controls

Detect security incidents. Examples: IDS, SIEM, Logs, CCTV, File integrity monitoring, Security monitoring.

Attack → IDS → Alert

Corrective Controls

Reduce damage and restore systems after an incident. Examples: Backup restoration, Patch installation, Malware removal, Password reset, Rebuilding compromised systems, Block attacker IP.

Attack → System Compromised → Restore Backup

13.1 Server Hardening

Meaning

The process of reducing a server's attack surface and vulnerabilities by removing unnecessary services, closing unused ports, applying secure configurations, enforcing least privilege, and keeping the system patched. It is the practical, hands-on application of the **Preventive Control** and "**reduce attack surface**" ideas above — turning a default, loosely-configured server into a locked-down one.

Default Server (many open doors) → Server Hardening → Minimal Server (only required doors open)

Why It Matters

A freshly installed OS is configured for **convenience, not security** — extra services run by default, default accounts/passwords may exist, and unnecessary ports are open. Hardening closes these gaps before attackers can use them.

Areas of Server Hardening

1. OS Hardening — Remove/disable unused software and services; disable unused default accounts (e.g. guest); apply latest OS patches and security updates; enable and configure host-based firewall (iptables/firewalld/ufw); set strong password policy + account lockout thresholds. **2. Network Hardening** — Close all ports except those required; use SSH key authentication instead of passwords; change default SSH port (optional, security-through-obscurity); restrict access using firewall rules/security groups (allow only trusted IPs); disable unused network protocols. **3. Account & Access Hardening** — Apply principle of least privilege; disable root/administrator direct login where possible; use `sudo` with logging instead of shared root access; enforce MFA for privileged accounts; remove/rotate default credentials. **4. Application & Service Hardening** — Run services with least-privileged (non-root) service accounts; disable directory listing, verbose error messages, default banners; remove sample/default files and admin panels; keep application dependencies patched. **5. File System Hardening** — Set correct file and directory permissions; enable file integrity monitoring; encrypt sensitive data at rest; set up regular, tested backups. **6. Logging & Monitoring**

Hardening — Enable centralized logging (auth logs, system logs); forward logs to a SIEM; set up alerts for failed logins/privilege escalation; enable auditd (Linux) for detailed system auditing.

Example — Hardening a Linux SSH Server

```
Before: Root login Enabled | Password login Enabled | SSH Port 22 open to 0.0.0.0/0 | Unused services running (ftp, telnet) | Firewall Disabled
After: Root login Disabled | Password login Disabled (SSH keys only) | SSH restricted to trusted IPs via firewall | Unused services removed | Firewall Enabled (deny all, allow required) | Fail2ban Enabled
```

Pros and Cons

Pros — Significantly reduces attack surface; prevents many common automated attacks (brute force, worms); often required for compliance (CIS Benchmarks, PCI-DSS, ISO 27001). **Cons** — Can break functionality if done without testing; needs ongoing maintenance (new patches, new services); requires documentation so legitimate admins aren't locked out.

Use Cases

Hardening a new EC2/VM instance before deployment; hardening a Kubernetes node or container base image; preparing a server for a compliance audit (CIS Benchmark scoring); post-incident hardening after a breach.

Real-Life Example

```
New Linux Server on AWS EC2 → Default: 22, 80, 443, 3306, 21 all open
Hardening Applied: Close 21 (ftp) and 3306 (restrict to internal only); SSH key-only login, no root login; Security Group allows 22 only from office IP; OS patched, Fail2ban + auditd enabled
Result: Attack Surface reduced from 5 ports to 2
```

Interview Definition

Server Hardening is the process of securing a server by reducing its attack surface — removing unnecessary services, closing unused ports, enforcing least privilege, applying patches, and configuring secure defaults — so there are fewer ways for an attacker to gain access.

14. Defence in Depth

Meaning

Using multiple layers of security so that if one security control fails, other controls can still protect the system. Never depend on only one security control.

Example Architecture

```
Internet → Firewall → IDS/IPS → DMZ → WAF → Application → Authentication+MFA →  
Database Access Control → SIEM Monitoring
```

An attacker must bypass multiple layers.

Defence in Depth Example

Suppose an attacker steals a password.

```
Without: Password Stolen → Login Successful → Full Access  
With: Password Stolen → MFA → Blocked  
Even if MFA is bypassed: Network Segmentation → Limited Access  
Even if suspicious activity happens: SIEM/IDS → Alert Generated
```

15. Why Defence in Depth is Important

No single security system is perfect. For example: Firewall may miss application attacks; IDS may miss new attacks; Password may get stolen; Antivirus may miss new malware. Therefore multiple security layers are used: Firewall + IDS/IPS + MFA + Endpoint Security + Network Segmentation + SIEM + Backups.

18. Your SSH Example — Detailed

Original example:

```
Open SSH port + weak password → Brute-force risk → MFA + Firewall + Fail2ban
```

Let's break it down.

- **Asset:** Linux Server
- **Exposure:** SSH Port 22 exposed to Internet
- **Vulnerability:** Weak Password
- **Threat:** External Attacker
- **Attack Vector:** SSH Login
- **Attack:** Brute Force
- **Risk:** Unauthorized Access

Possible Impact

Data theft, Malware installation, Privilege escalation, Server takeover, Lateral movement.

Countermeasures

Firewall Restriction + SSH Key Authentication + Strong Password + MFA + Fail2ban + Monitoring.

Note: Every one of these countermeasures is also part of standard **Server Hardening** (Section 13.1).

22. One-Line Interview Revision

Information Security → Protecting information and systems.
CIA Triad → Confidentiality + Integrity + Availability.
Security vs Privacy → Security protects data; Privacy controls how data is used and shared.
Vulnerability → Weakness.
Threat → Something capable of exploiting a weakness.
Risk → Likelihood and impact of exploitation.
Attack Vector → Method used by attacker.
Attack Surface → All possible attack points.
Exposure → How reachable or visible an asset is.
Countermeasure → Security control that reduces risk.
Risk Management → Identify → Assess → Treat → Monitor.
Security Controls → Preventive → Detective → Corrective.
Server Hardening → Reducing attack surface via secure OS/network/account/app configuration.
Defence in Depth → Multiple layers of security.

Best relationship to remember

Threat + Vulnerability → Risk → Countermeasure → Reduced Risk

For interviews, remember one complete example:

Weak SSH Password → Vulnerability
Attacker → Threat
SSH Brute Force → Attack Vector
Server Compromise → Risk
Firewall + SSH Keys + MFA + Fail2ban + SIEM → Countermeasures / Defence in Depth / Server Hardening